23.05.2025 (M)

SOMAIYA
VIDYAVIHAR UNIVERSITY

Semester: January 2025 –April 2025		
Maximum Marks: 100	**Examination: ESE Examination**	**Duration:3 Hrs.**
Programme code: 55 **Programme: Cyber Security & Forensics (Honors).**	**Class:** L.Y.B.Tech	**Semester: VII (SVU 2020)**
Institute/School/Department: K. J. Somaiya School of Engineering	**Name of the department:** Computer Engineering	
Course Code: 116h55C701	**Name of the Course: Secure Coding**	
Instructions: 1)Draw neat diagrams 2) All questions are compulsory 3) Assume suitable data wherever necessary		

Que. No.	Question	Max. Marks
Q1	Solve *any* **Four**	**20**
i)	Mention any five goals of threat modelling.	5
ii)	Elaborate on the secure coding practices for C++ programming language.	5
iii)	How do we prevent XSRF attacks?	5
iv)	What are the risks of reusing IVs (Initialization Vectors) in symmetric encryption algorithms like AES?	5
v)	List down the cryptographic techniques for password management.	5
vi)	What do you understand by verification and validation test?	5

Que. No.	Question	Max. Marks
Q2 A	Solve the following:	**10**
i)	How can the use of third-party libraries affect an application's attack surface?	5
ii)	Give two examples of how developers can reduce the attack surface in a web application.	5
	OR	
Q2 A	A company is developing a new web application for a bank. As a security analyst, you are asked to perform threat modelling. Describe how you would use the STRIDE model in this context.	10
Q 2 B	Solve *any* **One**	**10**
i)	Illustrate with the help of examples different string functions in C programming language which can lead to buffer overflow problem.	10
ii)	Explain with supporting example why input validation alone is not enough to prevent SQL injection attacks.	10

Que. No.	Question	Max. Marks
Q3	Solve *any* **Two**	**20**
i)	You are performing a code review for a web application developed by a junior team. The application allows users to upload images, create posts, and leave comments. During your review, you identify the following issues:	10

	• Input from users is inserted directly into HTML without sanitization. • Uploaded image files are stored with their original filenames and no content-type checks. • SQL queries are constructed using string concatenation with user inputs. • Debug mode is enabled in the production environment. • Error messages show detailed stack traces and file paths. Explain how applying the principle of "*fail securely*" would impact at least two of the issues identified.	
ii)	Define security misconfigurations? Explain the reasons leading to the occurrence of security misconfigurations?	10
iii)	What are the dangers of using outdated or broken cryptographic algorithms like MD5 or SHA-1 in applications? Give suitable examples to support your answer.	10

Que. No.	Question	Max. Marks
Q4	Solve *any* **Two**	**20**
i)	Describe how the lack of a salt when hashing passwords can lead to security breaches.	10
ii)	"*Every feature is a potential vulnerability.*" Critically analyze this statement in the context of secure software design. How does feature creep relate to the expansion of the attack surface?	10
iii)	Explain the concept of "*secure by design*". What practices can developers adopt to ensure that their applications are secure from the outset?	10

Que. No.	Question	Max. Marks
Q5	Solve *any* **four**	**20**
i)	SAST vs DAST.	5
ii)	Code injection attack.	5
iii)	Directory Traversal problem	5
iv)	Code obfuscation.	5
v)	Guidelines for using encryption techniques.	5
vi)	Sandboxing in Java.	5